

17. App에 보안 설정하기

Task

- Modify the existing Deployment named sc-deploy running in namespace prod so that its containers:

Path: ~/security/sc-dployment.yaml

- run with user ID 3000
- Privilege escalation is forbidden
- Have the NET_ADMIN capability added

보안 설정 이해하기

- Pod 레벨에서 보안 설정을 하면, 하위 컨테이너에 모두 적용됨.
- 컨테이너 레벨 보안 설정을 하면, Pod 설정을 덮어 씌움.
- 보안 설정을 하지 않으면 root 설정으로 서비스를 띄움.

```
apiVersion: v1
kind: Pod
metadata:
  name: secure-pod
spec:
  securityContext:
    runAsNonRoot: true
    runAsUser: 1000
    runAsGroup: 3000
    fsGroup: 2000

  containers:
    - name: app
      image: nginx:1.27

      securityContext:
```

```

runAsUser: 1000
  runAsGroup: 3000
  runAsNonRoot: true

allowPrivilegeEscalation: false
previleged: false

capabilities:
  add: ["NET_ADMIN", "SYS_TIME"]

readOnlyRootFilesystem: true
seccompProfile:
  type: RuntimeDefault

```

설정	의미
runAsNonRoot	root 사용자로 실행되는 것을 금지
runAsUser	컨테이너 프로세스의 UID 지정
runAsGroup	기본 GID 지정
fsGroup	Volume 연결 시 파일/디렉토리 소유 ID, pod 단위로만 설정 가능
allowPrivilegeEscalation	자신의 권한보다 높은 권한을 얻는 것을 금지, Container 단위로만 설정 가능
privileged	root로 컨테이너로 띄웠을 때 호스트 접근 권한 비활성화 오픈소스를 띄울 때 root 권한으로 띄워야 하는 경우가 있음. 이 경우, root 권한으로 띄워도 호스트 접근 권한은 막는 경우에 사용
capabilities	필요한 특정 권한만 추가
readOnlyRootFilesystem	true면 컨테이너를 읽기 전용으로 고정, 읽기 전용인 경우 앱 로그나 임시파일도 만들 수 없다는 제약이 존재함.
seccompProfile	런타임별 기본 보안 프로필 적용 런타임 container-d의 경우 root로 컨테이너를 띄워도 NET_ADMIN에 대한 권한은 자동으로 제외를 시켜줌. → 기본적인 보안 사항은 지킬 수 있게 됨.

Kubernetes 문서

- Securitycontext
<https://kubernetes.io/docs/tasks/configure-pod-container/security-context/>

문제 풀이

- deploy yaml 파일 수정

```
vi ~/security/sc-deployment.yaml
```

- containers 하위에 보안 설정 하기

```
spec:
  containers:
    - name: exam
      image: ipro/exam

      securityContext:
        runAsUser: 3000
        allowPrivilegeEscalation: False
        capabilities:
          add: ["NET_ADMIN"]
```

- 배포하기

```
k apply -f ~/security/sc-deployment.yaml
```